

DDoS Attack response

Availability · **Critical** severity · SOC IR Playbook

Incident type	Network/Application Layer Availability Attack
Severity	Critical
Priority	Critical if sustained outage or service degradation occurs
Detection sources	NOC alerts, SIEM, firewall logs, application monitoring tools, CDN/WAF, ISP notifications

Scenario

An external attacker launches a distributed denial-of-service (DDoS) attack targeting public-facing infrastructure such as websites, APIs, DNS servers or network gateways. The objective is to disrupt service availability, degrade performance or cause reputational and financial damage.

MITRE ATT&CK

T1498, T1498.001, T1499

Preparation

Implement DDoS protection Use cloud-based mitigation services (e.g., Cloudflare, AWS Shield, Akamai) Deploy WAF and rate limiting Protect applications and APIs Ensure scalable infrastructure Use autoscaling groups or CDN caching to absorb surges Establish communication with ISP Predefine escalation process and mitigation support Conduct DDoS drills Simulate DDoS scenarios and validate response procedures

Detection & Analysis

Identify traffic surge Monitor bandwidth, request rates or connection counts exceeding normal thresholds Determine attack vector Is it volumetric (UDP flood), protocol (SYN flood) or application-layer (HTTP GET flood)? Correlate with logs Identify source IPs, user agents, referrers, payloads Confirm impact Assess performance degradation, service outages or collateral damage

Containment

Engage cloud DDoS mitigation service Route traffic through mitigation provider (e.g., Cloudflare Magic Transit) Block malicious IPs Using firewall, WAF or geo-blocking rules Implement rate limiting and filters Drop traffic by rate thresholds or specific patterns Redirect or reroute traffic Temporarily divert traffic to alternate IP or load balancer

Eradication

Drop traffic from confirmed malicious sources Based on IP reputation or behavioural patterns Adjust filtering rules Fine-tune ACLs, WAF policies, IDS/IPS signatures Remove temporary rules post-attack Once attack subsides, restore normal access patterns Investigate for blended threats Confirm no malware or lateral movement occurred during the disruption

Recovery

Monitor for residual traffic Use NOC dashboards and SIEM to track post-attack anomalies Confirm service restoration Perform user acceptance testing or API health checks Notify affected customers or partners If SLAs or public services were impacted Resume normal routing If temporary redirection or black-holing was used during attack

Lessons Learned & Reporting

Conduct incident review Document timeline, impact, attacker strategy and response actions Assess mitigation effectiveness Determine what worked and what needs to be improved Update response playbook Refine thresholds, alerting rules and communication steps Improve vendor coordination Review performance of ISP and mitigation partners Report as required To regulators, leadership or clients if impact was severe or prolonged

Tools typically involved

SIEM (e.g., Splunk, Sentinel, QRadar); Network traffic analysis tools (e.g., NetFlow, Zabbix, Ixia); DDoS protection services (e.g., Cloudflare, AWS Shield, Akamai Kona, Arbor); Firewall/WAF (e.g., Fortinet, Palo Alto, ModSecurity); CDN and DNS services (e.g., Cloudflare, Fastly, Akamai); ISP support and coordination channels

Success metrics (SLA targets)

Time to Detect DDoS <5 minutes from onset Mitigation Engagement Time <15 minutes from confirmation Service Downtime Zero or <30 minutes Customer Notification Time Within 1 hour if SLA is affected Post-Mortem Completion Within 48 hours